“Año de la Esperanza y el Fortalecimiento de la Democracia”

UNIVERSIDAD TECNOLÓGICA DEL PERÚ

Curso:

Curso integrador 1: Sistema software

Tema:

Auditoria al sistema de OrderFast

Docente:

IVAN GUSTAVO HUAMAN TORRES

Integrantes:

Will Smith Ramos Llamocca – U22305797

Espejo Chacaltana Sebastian Imanol – U23266563

Zamora Zamudio Darick Hanssel – U22217326

Ica - Perú – 2026

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT2: MANTENIMIENTO DE SOFTWARE DE APLICACIÓN.	
1. Verificar si el diseño de las nuevas aplicaciones o de las modificaciones a los módulos puestos en producción, son revisados y aprobados por la Gerencia de TI. **Resultado: No verificado** **Respuesta:** El segundo avance presenta el diseño de la solución. No se adjuntó una constancia de revisión del docente o del responsable del equipo que permita comprobar su aprobación.	Avance 2 pp. 23-24 §14 Sin acta de aprobación.
2. Verificar e Identificar quienes son los responsables de aprobar cualquier proyecto de desarrollo, implementación o modificación. **Resultado: No verificado** **Respuesta:** El documento identifica a los integrantes del proyecto, pero no precisa quién aprueba los cambios. Para esta etapa basta dejar registrada esa responsabilidad dentro del equipo.	Avance 2 p. 1 Integrantes Sin encargado de aprobación.
3. Verificar si existen procedimientos definidos o estándares, para las etapas de desarrollo de un nuevo sistema o cambios a los ya existentes. **Resultado: Parcial** **Respuesta:** El avance describe un desarrollo iterativo y una arquitectura por módulos. El repositorio separa interfaz, API y lógica de negocio; falta precisar los criterios que el equipo utiliza para dar por terminada cada actividad.	Avance 2 p. 7 §2.6 Repo: README.md L25-33
4. Verificar si cuentan con mecanismos para identificar los requerimientos de seguridad y control interno para cada proyecto de desarrollo o modificación de sistemas de información, previo a su desarrollo. **Resultado: Parcial** **Respuesta:** El requisito RNF01 contempla autenticación, roles y validación de datos. Su aplicación es parcial: la consulta y la cancelación de pedidos de invitados requieren comprobar el derecho de acceso del solicitante.	Avance 2 p. 7 RNF01 Repo: order.routes.ts L22-30

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
5. Verificar e identificar si se incluyen en el diseño de las nuevas aplicaciones o en las modificaciones de sistemas de información, controles de aplicación que garanticen que los datos de entrada y salida estén completos. **Resultado: Parcial** **Respuesta:** El código valida datos con Zod y calcula los importes en el servidor. Falta comprobar la titularidad del pedido antes de devolver información o aceptar una cancelación.	Repo: order. schemas.ts L6-24 Repo: order. service.ts L64-80 Acceso: L186-190, L288-304.
6. Verificar si consideran aspectos básicos de seguridad y control interno del módulo a ser desarrollado o modificado, y estos son evaluados junto con el diseño conceptual del mismo. **Resultado: Parcial** **Respuesta:** Se incorporan autenticación con Supabase y permisos por rol. La revisión del diseño debe incluir también el acceso a cada pedido, porque disponer de su identificador no acredita que pertenezca al solicitante.	Repo: auth. middleware.ts L7-67 Repo: order.routes.ts L22
7. Identificar si existe una metodología estándar para el desarrollo de un plan de pruebas, en donde se incluyan pruebas unitarias, pruebas de aplicación, pruebas de integración y pruebas de carga y estrés, para cada módulo. **Resultado: Parcial** **Respuesta:** En la revisión previa se registraron 30 pruebas aprobadas: 19 de backend y 11 de frontend. Para este avance conviene completar los casos de acceso al pedido desde otra sesión; no se acreditaron pruebas de integración de autorización ni de carga.	Avance 2 p. 7 §2.6 Repo: Pruebas de estados L4-60 Repo: Pruebas de carrito L4-27
8. Verificar si la formulación del procedimiento de prueba y los datos de prueba son revisados y aprobados por el jefe de programación. **Resultado: No verificado** **Respuesta:** No se presentó un registro de revisión de los casos y datos de prueba. En el contexto académico puede documentarse mediante una lista de casos revisada por el equipo y presentada al docente.	Avance 2 pp. 15-16 §7 Sin acta de revisión de pruebas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
9. Verificar si se aplican adecuadas medidas de seguridad para prevenir divulgación de información sensitiva durante las pruebas. **Resultado: No verificado** **Respuesta:** Las pruebas unitarias revisadas emplean datos de prueba. No se comprobó la separación de datos y credenciales en todos los entornos utilizados por el equipo.	Avance 2 p. 14 §6.5.6 Repo: Datos de prueba L4-7
10. Verificar que los resultados de las pruebas son revisados y aprobados por el usuario. **Resultado: No verificado** **Respuesta:** No se aportó evidencia de pruebas de aceptación con usuarios. Para el segundo avance corresponde registrar la demostración de las funciones implementadas y las observaciones recibidas.	Avance 2 pp. 15-16 §7 Sin pruebas de aceptación aportadas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT3: CONTROLES DE PROGRAMAS Y APLICACIONES.	
1. Verificar el conteo de la cantidad de “byte” de los programas fuentes actuales para hacer una comparación rápida entre la cantidad de byte de estos y los autorizados que se trasladaron a producción para alertar en caso de modificaciones. **Resultado: No verificado** **Respuesta:** El repositorio utiliza Git para identificar versiones y cambios. No se comprobó que el despliegue corresponda exactamente al commit revisado; conviene registrar la versión presentada en cada avance.	Repo: commit 4004844 Despliegue no contrastado.
2. Verificar que exista un archivo lóg o bitácora que permita identificar los errores de ejecución de aplicaciones, sistema operativo y BD. **Resultado: Parcial** **Respuesta:** Existe registro de eventos con Pino. Algunas tareas de notificación descartan errores sin registrarlos, lo que dificulta identificar fallas durante las pruebas del proyecto.	Repo: logger.ts L1-15 Repo: order. service.ts L258-276
3. Verificar si han considerado todos los dispositivos de seguridad que fueron recomendados por el fabricante o el programador. **Resultado: No verificado** **Respuesta:** Se identificaron validaciones, autenticación y controles por rol. No se verificó la configuración completa de seguridad de los servicios externos utilizados.	Avance 2 p. 9 §5.1.2 Repo: app.ts L32-44
4. Verificar que exista una persona responsable en el área de TI de revisar periódicamente los archivos lóg o bitácoras de los sistemas. **Resultado: No verificado** **Respuesta:** El material revisado no identifica a un integrante encargado de revisar los errores registrados. Es conveniente asignar esta tarea durante las pruebas de cada avance.	Avance 2 p. 16 §7.2 Sin encargado de revisar bitácoras.
5. Verificar que la institución respete los límites de la capacidad de procesamiento recomendados por el proveedor como: memoria, espacio en disco, procesamiento CPU. Para garantizar el correcto funcionamiento de las aplicaciones informáticas. **Resultado: No verificado** **Respuesta:** No se revisaron métricas ni cuotas de los servicios contratados. Para este avance corresponde comprobar que los recursos disponibles soporten la demostración y las pruebas previstas.	Avance 2 p. 13 §6.5.3 Sin métricas de capacidad.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
6. Verificar que la institución cuente con un servidor de desarrollo que sea de uso de los programadores para el desarrollo y pruebas de las aplicaciones internas. **Resultado: No verificado** **Respuesta:** El repositorio permite ejecutar pruebas en local y mediante integración continua. No se verificó un entorno separado que reproduzca todas las condiciones del despliegue.	Repo: README.md L35-71 Repo: backend-ci.yml L15-30 Entorno aparte no verificado.
7. Verificar que los programadores no tengan acceso a la línea de comandos, en los servidores de producción y acceso a estos para consultas. **Resultado: No verificado** **Respuesta:** No se inspeccionaron los permisos de las cuentas de despliegue. El equipo debe identificar quién puede publicar cambios y proteger esas credenciales.	Avance 2 p. 14 §6.5.6 Permisos del despliegue sin revisar.
8. Verificar si existe una persona responsable dentro del área de tecnología en cargada de ejecutar programas de diagnóstico de la red institucional. **Resultado: No verificado** **Respuesta:** No se presentó evidencia de diagnósticos de red. Al tratarse de una aplicación alojada en servicios externos, debe distinguirse la conectividad del equipo de la infraestructura administrada por los proveedores.	Avance 2 p. 13 §6.5.4 Sin diagnóstico de red.
9. Verificar que exista un procedimiento de control de cambios de los programas y del traslado del ambiente de desarrollo a producción. **Resultado: Parcial** **Respuesta:** Git y los archivos de integración continua aportan control de versiones y comprobaciones automáticas. Falta documentar quién revisa y publica los cambios de la versión presentada.	Repo: backend-ci.yml L1-30 Repo: frontend-ci.yml L1-36

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
10. Verificar que no exista más de un usuario además del administrador con el perfil de mantenimiento de parámetros de los módulos de las aplicaciones informáticas. **Resultado: No pasó (escritorio); cuentas no verificadas** **Respuesta:** La administración implementada es web; no se identificó una aplicación de escritorio ni un instalador. Esto deja pendiente el requisito docente comunicado para el rol administrador. Debe desarrollarse el cliente de escritorio con las funciones exigidas, conectado a la API y sujeto a sus permisos. No se verificó el número real de cuentas administrativas.	Avance 2 pp. 10-12 §5.2 y §6.1 Repo: App.tsx L41-64 Escritorio: requisito docente comunicado por el solicitante.
11. Comprobar que la custodia de la documentación del software de Aplicación, los software utilitario entre otros estén controlados por personal de tecnología. **Resultado: No verificado** **Respuesta:** Existe documentación en el repositorio. Para este avance debe mantenerse vinculada a la versión presentada y señalar al integrante responsable de actualizarla.	Repo: README.md L25-33 Repo: FLUJO_Y_ MEJORA.md L91-111 Custodia sin acreditar.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT7: CONTROL DE ENTRADAS Y SALIDAS	
ENTRADAS (ORIGEN DE TRANSACCIONES)	
1. Verificar según sistema cuáles y cuántos son los aplicativos que se alimentan de forma automática y manual. **Resultado: Pasó** **Respuesta:** Los datos ingresan mediante los formularios de carta, carrito, checkout y administración, y por las rutas de la API. Estos son los canales identificados en la versión revisada.	Avance 2 p. 23 §14.1-14.2 Repo: App.tsx L19-24
2. Verificar si la estructura de los formularios que se utilizan como base para la captura de información son adecuados y completos de acuerdo a lo requerido por el sistema. **Resultado: Parcial** **Respuesta:** Los formularios cubren el flujo básico de pedido. El checkout no permite aplicar cupones ni registrar el método de pago; este último figura como pendiente para una siguiente iteración en el avance.	Avance 2 p. 22 §13.4 Repo: Checkout Page.tsx L56-141
3. Verificar la existencia de aplicativos que se alimentan por medio de dispositivos magnéticos de entidades externas, asimismo comprobar los mecanismos de control de calidad de los datos. **Resultado: No aplica** **Respuesta:** No aplica al flujo identificado: el proyecto no contempla importación de datos mediante dispositivos magnéticos de otras entidades.	Avance 2 pp. 11-13 §6.2-6.4
4. Verificar e identificar filtros de alertas o mensajes del sistema que permitan controlar la calidad de información que será ingresada. **Resultado: Pasó** **Respuesta:** La API valida las entradas con Zod y devuelve mensajes de error. En la carta se deshabilita la incorporación de productos sin stock.	Repo: validate.ts L8-20 Repo: Product Card.tsx L17-54
5. Verificar según muestra de documentos fuente, aspectos como cifras de control firma de autorización y similares. **Resultado: No aplica** **Respuesta:** No se utilizan documentos físicos con firmas como origen del pedido. En este flujo la autorización debe comprobarse mediante la identidad, la sesión y los permisos del solicitante.	Avance 2 p. 11 §6.2.1 y §6.2.4

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
6. Verificar si existe un control a nivel de perfil de usuarios que ingresan datos para evitar ingreso de datos por usuarios no autorizados. **Resultado: No pasó** **Respuesta:** Existen restricciones por rol en las funciones administrativas. Sin embargo, el código permite consultar pedidos por su identificador y cancelar pedidos pendientes de invitados sin acreditar su titularidad; debe corregirse la autorización en la API.	Repo: order.routes.ts L22-30 Repo: order. service.ts L288-304
7. Verificar que existan restricciones controladas para el uso de diversos dispositivos magnéticos de entrada. **Resultado: No aplica** **Respuesta:** No aplica al alcance del segundo avance: el ingreso de pedidos se realiza mediante formularios web, sin captura desde dispositivos magnéticos.	Avance 2 p. 11 §6.1 y §6.2.1
8. Verificar que cuando se diseñen formas, los campos de datos importantes tengan predefinido un formato de ingreso de datos, con el fin de minimizar errores. **Resultado: Parcial** **Respuesta:** Se definen tipos y formatos de entrada. El arreglo de productos no tiene un máximo explícito por pedido; conviene acotarlo y comprobar cantidades válidas.	Repo: order. schemas.ts L6-24
9. Verificar que existan controles sobre los documentos de propiedad con números de series secuenciales y el ingreso de dichos números al sistema para crear la relación entre ambos. **Resultado: No aplica** **Respuesta:** No aplica al proceso descrito: OrderFast no gestiona documentos de propiedad seriados como origen de las transacciones.	Avance 2 p. 11 §6.2.4
10. Verificar que exista un registro de la fecha de proceso y la fecha de transacción para las transacciones de entrada. **Resultado: Pasó** **Respuesta:** Los modelos de pedidos incorporan fechas de creación y actualización. Esta comprobación se limita a su definición en el código revisado.	Repo: order.model.ts L18-51 Avance 2 p. 10 §5.1.7

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
11. Verificar si a los documentos ingresados, se les asigna una marca de control o sello con la finalidad de asegurase que estos no sean ingresados nuevamente. **Resultado: No aplica** **Respuesta:** No aplica el sellado de documentos físicos. En el flujo digital debe comprobarse que los reintentos de envío no generen pedidos duplicados; esa prueba no quedó acreditada.	Avance 2 p. 23 §14.2 Reintentos sin prueba aportada.
12. Verificar qué mecanismos utilizan para identificar si existen documentos de entrada no ingresados al sistema. **Resultado: No verificado** **Respuesta:** No se presentó una comprobación que contraste los pedidos enviados desde la interfaz con los registrados. Para el avance conviene incluir ese caso en las pruebas del flujo completo.	Avance 2 p. 7 §2.6 Repo: Checkout Page.tsx L45-53
13. Verificar el cumplimiento del artículo de 451 y 455 del Código de Comercio, que relaciona al período de resguardo de la información fuente u original. **Resultado: No verificado** **Respuesta:** No se ha determinado la pertinencia de los artículos legales citados por el modelo. Su cumplimiento no puede calificarse sin identificar primero la norma y la jurisdicción aplicables al proyecto.	Modelo de auditoría: PT7, entrada 13. Norma aplicable no determinada.
14. Comprobar el control utilizado para demostrar que la información a ingresar se encuentra autorizada. **Resultado: No pasó** **Respuesta:** La cancelación de pedidos pendientes de invitados no comprueba la titularidad en el código revisado. Debe validarse la identidad o credencial del invitado antes de modificar el pedido.	Repo: order. service.ts L288-304 Avance 2 p. 21 HU16
15. Identificar si la institución realiza un control de calidad sobre el estado de los documentos que van a ser digitalizados para ser almacenados como imagen. **Resultado: No aplica** **Respuesta:** No aplica al alcance identificado: el registro de pedidos no incluye digitalización de documentos fuente.	Avance 2 p. 11 §6.2.1 y §6.2.4

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
16. Verificar qué procedimientos existen para el manejo de errores con el fin de proporcionar al personal usuario instrucciones para la corrección de errores en los documentos fuentes. **Resultado: Parcial** **Respuesta:** La API valida datos y devuelve errores. Falta registrar cómo se corrige una entrada rechazada y comprobar que el usuario pueda continuar sin perder información válida.	Repo: validate.ts L8-20 Repo: errorHandler.ts L15-48
17. Revisar los tipos de errores y las razones de su ocurrencia con el fin de determinar si los problemas son ocasionados por el programa o por ingreso incorrecto de datos. **Resultado: Parcial** **Respuesta:** Existen validadores y pruebas de reglas de negocio. No se revisó un registro de incidencias que permita separar errores del programa de errores de ingreso.	Repo: order. schemas.ts L6-24 Repo: Pruebas de estados L4-60
18. Verificar si se obtiene una copia del LOG que registra el sistema en relación a las entradas de datos. **Resultado: No verificado** **Respuesta:** Se identificó un mecanismo de registro de eventos. No se obtuvo una bitácora del despliegue que permita verificar qué entradas quedan registradas y durante cuánto tiempo.	Repo: logger.ts L1-15 Sin bitácora del despliegue.
SALIDAS	
1. Verificar si existe un inventario de reportes, que identifique: nombre del programa, nombre del módulo, unidad destino, frecuencia de emisión y medio de emisión. **Resultado: Parcial** **Respuesta:** Se identifican pantallas de seguimiento y respuestas de la API. El avance no presenta un inventario de salidas con sus usuarios destinatarios; puede documentarse para las funciones implementadas.	Avance 2 p. 24 §14.3-14.4 Sin inventario de salidas.
2. Verificar el proceso de distribución de los reportes de manera que se envíen al personal autorizado. **Resultado: No pasó** **Respuesta:** La consulta del pedido devuelve información a quien conoce el identificador, sin comprobar titularidad. Esto es coherente con el acceso desde incógnito comunicado por el solicitante; la API debe autorizar la consulta antes de entregar los datos.	Repo: order.routes.ts L22 Repo: order. service.ts L186-190

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
3. Verificar el área donde se resguardan los reportes confidenciales de manera que el personal no autorizado no pueda tener acceso a ellos. **Resultado: No pasó** **Respuesta:** La información del pedido no queda limitada a su titular o al personal autorizado. Debe aplicarse autorización en el servidor y devolver únicamente los datos necesarios para cada usuario.	Avance 2 p. 7 RNF01 Repo: order. service.ts L186-190
4. Comprobar que se eliminen de forma inmediata los archivos de salida, no finalizados cuando sean confidenciales. **Resultado: No verificado** **Respuesta:** No se identificó un flujo de generación de archivos temporales confidenciales en las funciones revisadas. El tratamiento de otros archivos del entorno no fue inspeccionado.	Avance 2 p. 13 §6.4 Archivos del entorno sin revisar.
5. Verificar que exista un responsable de efectuar un análisis general de los reportes con el objeto de determinar si hay reportes que puedan ser eliminados, fusionados, reagrupados, simplificados, o si se requiere nuevos reportes. **Resultado: No verificado** **Respuesta:** No se identificó al responsable de revisar las salidas del sistema. Para el segundo avance esta tarea puede asignarse a un integrante que contraste las pantallas con los requisitos.	Avance 2 pp. 14-16 §7 Sin responsable de salidas.
6. Evaluar quién ejerce la función de control de calidad en los reportes emitidos. **Resultado: No verificado** **Respuesta:** No se aportó evidencia específica de pruebas de las salidas. Deben comprobarse el detalle, el total y el estado del pedido, además de quién puede consultarlos.	Avance 2 pp. 15-16 §7 Sin evidencia de pruebas de salidas.
7. Verificar si los encabezados de cada reporte incluyen los siguientes aspectos: fecha de generación, nombre del programa, período cubierto de proceso, titulo descriptivo del contenido del reporte, usuario que generó, número de identificación del programa, número de página, etc. **Resultado: Parcial** **Respuesta:** El seguimiento muestra identificador, productos, importes, estado e historial del pedido. No se verificó un formato de reporte documental para todas las salidas previstas.	Avance 2 p. 24 §14.3 Repo: OrderTracking Page.tsx L48-84

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
8. Verificar que se etiquete cada reporte o grupo de reportes de manera que se indique en el nombre del usuario, destino y el área o departamento al que pertenece. **Resultado: No verificado** **Respuesta:** No se presentó un catálogo con destinatarios y clasificación de las salidas. En las pantallas actuales debe quedar definido qué información corresponde al cliente, al personal y al administrador.	Avance 2 pp. 9-10 y 24 §5.1.2, §5.1.7 y §14 Sin catálogo de destinatarios.
9. Verificar la existencia de códigos que identifiquen el nivel de confidencialidad del reporte. **Resultado: No verificado** **Respuesta:** No se documentó una clasificación de los datos mostrados. Conviene distinguir la carta pública de la información de pedidos y clientes que requiere control de acceso.	Avance 2 p. 7 RNF01 Sin clasificación de datos.
10. Verificar cuál es el procedimiento para la destrucción de reportes sobrantes o que no estén en uso. **Resultado: No verificado** **Respuesta:** No se identificó un procedimiento de conservación o eliminación de reportes. Su definición puede incorporarse cuando se complete ese módulo; los pedidos existentes sí requieren reglas de conservación claras.	Avance 2 p. 13 §6.4 Sin política de conservación.
11. Verificar que mecanismos de control utilizan para producir únicamente la cantidad requerida de reportes solicitados. **Resultado: No verificado** **Respuesta:** No se acreditó un control de distribución de reportes. En la versión revisada debe priorizarse que cada consulta muestre únicamente la información autorizada.	Repo: order.routes.ts L12-22 Distribución no acreditada.
12. Evaluar el nivel de satisfacción de los usuarios respecto a la estructura de los reportes y a la confidencialidad de la información generada. **Resultado: No verificado** **Respuesta:** No se realizaron encuestas ni entrevistas a usuarios sobre estas salidas. Las pruebas del siguiente avance pueden recoger observaciones sobre claridad, utilidad y privacidad de la información.	Avance 2 p. 7 RNF04 Sin encuestas ni entrevistas.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
PT9: SEGURIDAD LÓGICA.	
1. Verificar que el software de comunicaciones exige código de usuario y contraseña para su acceso. **Resultado: No pasó** **Respuesta:** Las rutas protegidas verifican tokens de Supabase y aplican roles. La consulta de pedidos por identificador constituye una excepción: no comprueba que el solicitante tenga derecho a ver ese pedido.	Repo: auth. middleware.ts L22-43 Repo: order.routes.ts L22
2. Verificar si los usuarios no pueden acceder a ningún sistema, sin antes haberse autenticado correctamente en la red institucional. **Resultado: No pasó** **Respuesta:** Se reportó que el mismo enlace permite consultar el pedido desde incógnito; no se reprodujo ese enlace concreto. El código revisado es consistente con el reporte porque la consulta no exige acreditar titularidad. Debe validarse al titular en la API o vincular el pedido de invitado a una credencial de sesión. Para impedir el acceso al copiar solo el enlace, esa credencial debe quedar fuera de la URL; un enlace que incluya el secreto también funcionaría en incógnito.	Avance 2 p. 24 §14.3 Repo: order.routes.ts L22 Repo: order. service.ts L186-190 Incógnito: reporte del solicitante.
3. Verificar si se inhabilita al usuario después de ingresar la contraseña después un número determinado de intentos fallidos. **Resultado: No verificado** **Respuesta:** No se inspeccionó la política de intentos fallidos configurada en Supabase. Debe verificarse con una cuenta de prueba, sin asumir que el proveedor tiene activado un bloqueo específico.	Repo: LoginPage.tsx L21-24 Política externa no inspeccionada.
4. Verificar que el sistema operativo obliga a cambiar la contraseña periódicamente. **Resultado: No verificado** **Respuesta:** No se revisó la caducidad de contraseñas del proveedor. El criterio del modelo debe contrastarse con la política de autenticación definida para el proyecto.	Avance 2 p. 9 §5.1.2 Caducidad en Supabase no inspeccionada.

PROGRAMA DE AUDITORÍA DE SISTEMAS	FECHA INICIO:
INSTITUCIÓN: OrderFast	FECHA FIN:
AUDITOR: Equipo de CiviGo	FIRMA:

Áreas / Actividades	Referencia
5. Verificar que la contraseña no sea menor a 8 caracteres y que sea una combinación de números y letras, entre ellos mayúsculas y minúsculas. **Resultado: No verificado** **Respuesta:** No se comprobó la política efectiva de contraseñas en Supabase. El equipo debe revisar sus requisitos y contrastarlos con el formulario de registro.	Repo: LoginPage.tsx L21-24 Política efectiva de Supabase no comprobada.
6. Verificar que las contraseñas no son mostradas en pantalla cuando se ingresan. **Resultado: Pasó** **Respuesta:** El formulario de acceso utiliza un campo de tipo password, que oculta los caracteres mientras se escribe la contraseña.	Repo: LoginPage.tsx L45-52
7. Verificar si durante el procedimiento de identificación, los usuarios son informados de cuándo fue su última conexión para ayudar a identificar potenciales suplantaciones o accesos no autorizados. **Resultado: No pasó (mejora para otra etapa)** **Respuesta:** No se identificó un aviso de última conexión. Su incorporación puede evaluarse como mejora de seguridad; no se acreditó que sea un entregable exigido para este segundo avance.	Repo: LoginPage.tsx L17-65 Repo: AuthProvider .tsx L23-51
8. Verificar que existe software para llevar estadísticas que incluyan tasas de errores y de retransmisión. **Resultado: Parcial** **Respuesta:** Existen registros con Pino y comprobaciones de disponibilidad. Algunas notificaciones descartan errores sin registrarlos; debe corregirse ese manejo para facilitar las pruebas y el diagnóstico.	Repo: logger.ts L1-15 Repo: order. service.ts L258-276
9. Verificar que los equipos puedan validar la identificación electrónica de las terminales que se agregan a la red. **Resultado: No verificado** **Respuesta:** No se inspeccionó la red ni la identificación de los equipos conectados. Este control de infraestructura no puede valorarse a partir de la aplicación web presentada.	Avance 2 p. 13 §6.4-6.5 Red y equipos sin revisar.